BREACHSIEVE - Vulnerability Assessment Report

Target: https://juice-shop.herokuapp.com | Date: 2026-10-17 15:41:21 UTC

Risk Score	Critical	High	Medium	Low	False Positives	Novel Patterns
10.0	**2**	**0**	**0**	**0**	**4**	**0**

Scope & Authorization Record

Target URL	https://juice-shop.herokuapp.com
Scan Mode	PASSIVE (Active Confirmed: 0)
Authorization Status	CONFIRMED - Explicit authorization granted by operator
Authorized At	2026-10-17T15:39:29.340205+00:00
In-Scope Rules	juice-shop.herokuapp.com /rest/* /api/*
Out-of-Scope Rules	/ftp/*

Confirmed Vulnerability Findings (2)

[BS-FIND-003] Strict-Transport-Security Header Not Set - **Critical (CVSS: 10.0)**

CWE: CWE-319 | **OWASP:** A02:2021-Cryptographic Failures | **MITRE:** T1557
URL: https://juice-shop.herokuapp.com/assets/public/favicon_js.ico
Description: HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.
Gemini AI Verdict: [CONFIRMED] The request was made over HTTPS to "https://juice-shop.herokuapp.com/assets/public/favicon_js.ico", but the response headers ("X-Content-Type-Options: nosniff", "X-Frame-Options: SAMEORIGIN", etc.) completely lack the "Strict-Transport-Security" header. This leaves users susceptible to SSL-stripping and man-in-the-middle attacks on initial insecure connections.
Remediation: Configure the web server or reverse proxy to return the 'Strict-Transport-Security' response header (e.g., 'Strict-Transport-Security: max-age=31536000; includeSubDomains') on all HTTPS responses.

[BS-FIND-004] Content Security Policy (CSP) Header Not Set - **Critical (CVSS: 10.0)**

CWE: CWE-693 | **OWASP:** A05:2021-Security Misconfiguration | **MITRE:** T1562
URL: https://juice-shop.herokuapp.com
Description: Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Gemini AI Verdict: [CONFIRMED] The response returns HTML content as indicated by 'Content-Type: text/html; charset=UTF-8', but lacks both 'Content-Security-Policy' and 'Content-Security-Policy-Report-Only' headers. While other security headers like 'X-Content-Type-Options: nosniff' and 'X-Frame-Options: SAMEORIGIN' are present, the absence of a CSP leaves the application without defense-in-depth protection against cross-site scripting (XSS) and data injection attacks.
Remediation: Configure a strict Content Security Policy using the 'Content-Security-Policy' HTTP response header, defining permitted sources for scripts, styles, images, and other resources.

Remediation Summary Matrix

ID	Title	Severity	Actionable Fix
BS-FIND-003	Strict-Transport-Security Head	Critical	Configure the web server or reverse proxy to return the 'Strict-Transport-Security' respo
BS-FIND-004	Content Security Policy (CSP)	Critical	Configure a strict Content Security Policy using the 'Content-Security-Policy' HTTP resp

Methodology Note

This assessment was performed using automated OWASP ZAP scanning driven through its REST API, restricted to strictly verified in-scope allow-list rules. Alerts were triaged via Google Gemini API using evidence-based analysis to filter false positives and identify novel patterns. This automated assessment augments, not replaces, comprehensive manual security testing.